📚 Book Tracker

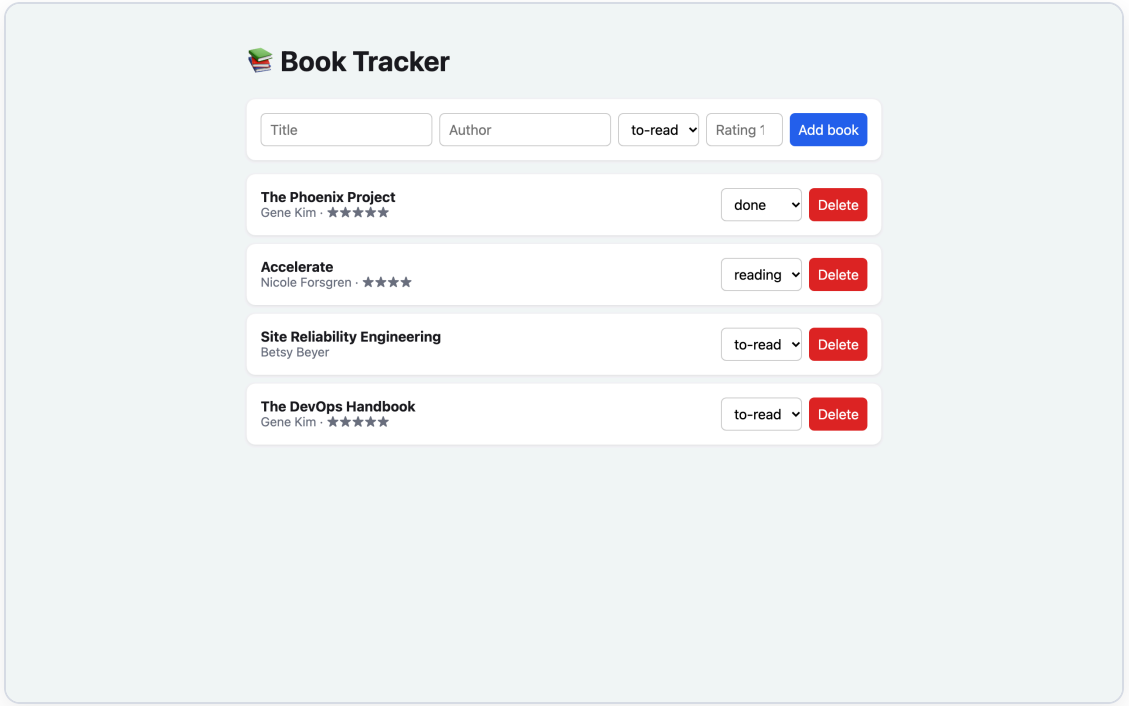
An end-to-end DevSecOps capstone: FastAPI + React + PostgreSQL,
shipped with CI/CD, Trivy, Terraform on AWS EKS, Helm, ArgoCD, Prometheus & Grafana

github.com/vanditabyaa09/book-tracker-devops

Project overview

What it does: track books you want to read, are reading, or have finished, each with an optional 1–5 rating.

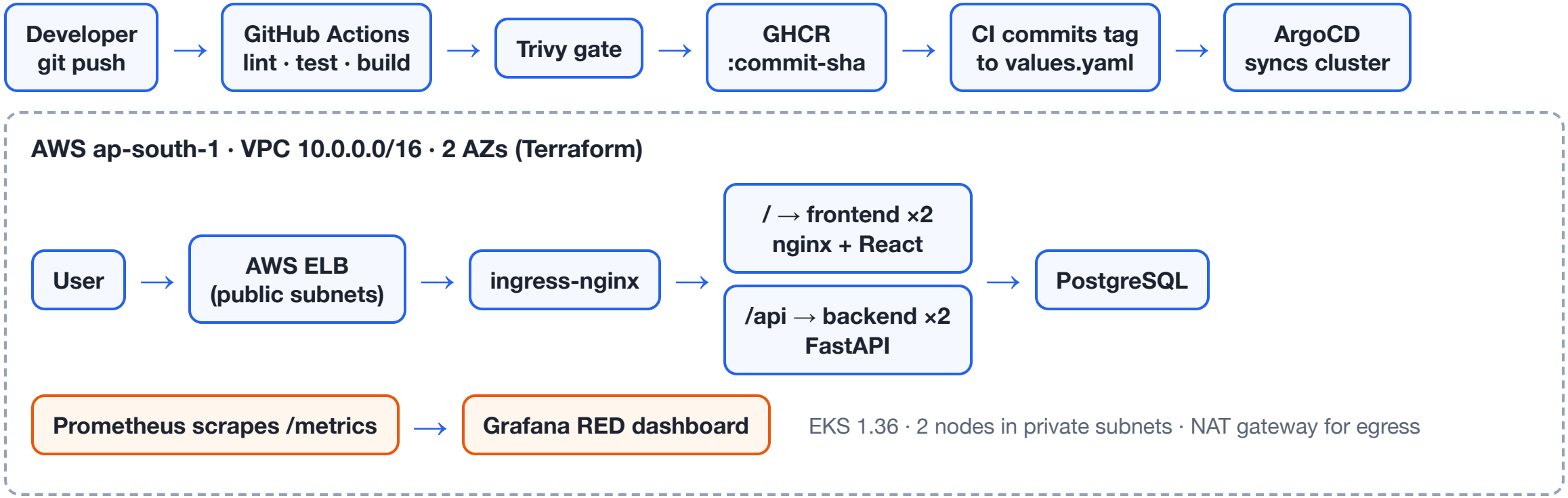
- FastAPI REST API: 5 CRUD endpoints + `/health` + `/metrics`
- PostgreSQL schema managed by **Alembic** migrations
- Responsive React UI; calls the API only through relative `/api` URLs
- The focus is everything *around* the code: how a commit becomes a tested, scanned, versioned image running on Kubernetes, provisioned from code and monitored live



Tech stack

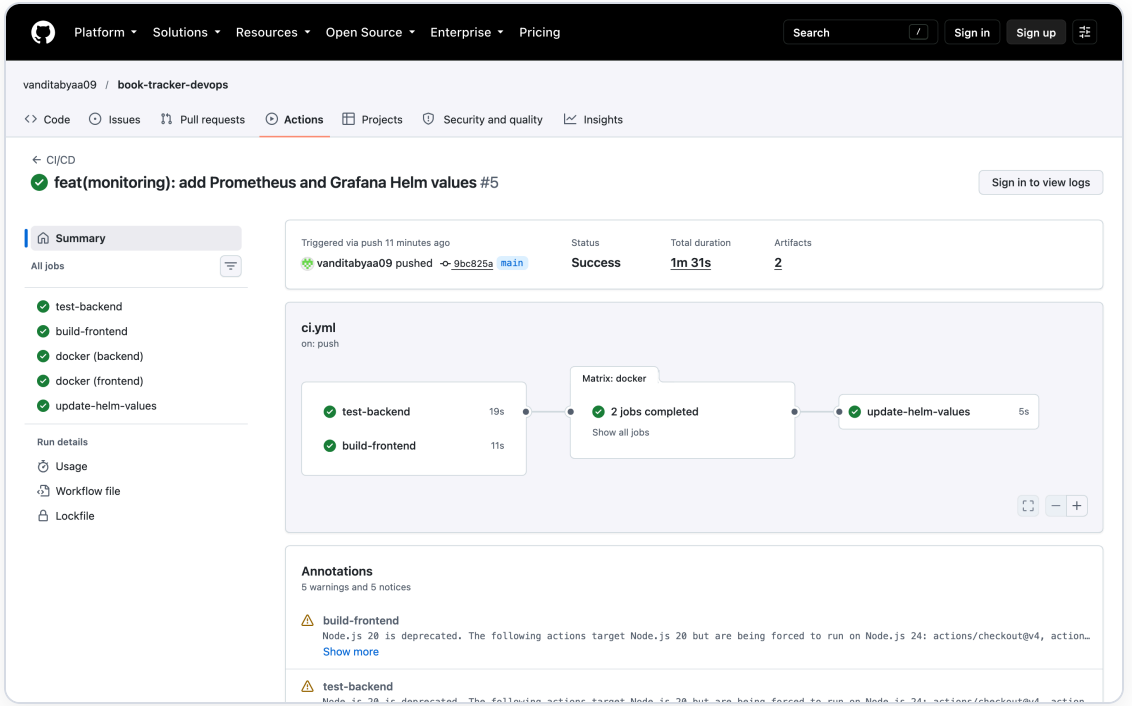
Layer	Tools
Application	Python 3.13 · FastAPI · SQLAlchemy 2 · Pydantic v2 · React 19 + Vite · nginx
Data	PostgreSQL 17 · Alembic
Quality	pytest (isolated SQLite test DB, 8 tests) · ruff
Containers	Docker (non-root, multi-stage frontend) · Docker Compose
CI/CD & registry	GitHub Actions · GitHub Container Registry (SHA tags)
Security	Trivy (fail on HIGH/CRITICAL) · SHA-pinned actions · no secrets in Git
Infrastructure	Terraform · AWS VPC · EKS 1.36 · managed node group (m7i-flex.large)
Kubernetes	Helm chart · ingress-nginx · ArgoCD (GitOps)
Observability	Prometheus (ServiceMonitor) · Grafana dashboard as code

Architecture



CI/CD flow (GitHub Actions)

- **Trigger:** every push to `main`
- **test-backend:** ruff + pytest. A failure stops the pipeline (`needs:`)
- **build-frontend:** `npm ci && npm run build`
- **docker** (matrix backend/frontend): build → **Trivy** → push to GHCR
- Tags = **Git commit SHA**, never `latest`
- **update-helm-values:** bot commits the new tag `[skip ci]`, and ArgoCD deploys it
- Auth via the short-lived `GITHUB_TOKEN`; no stored secrets



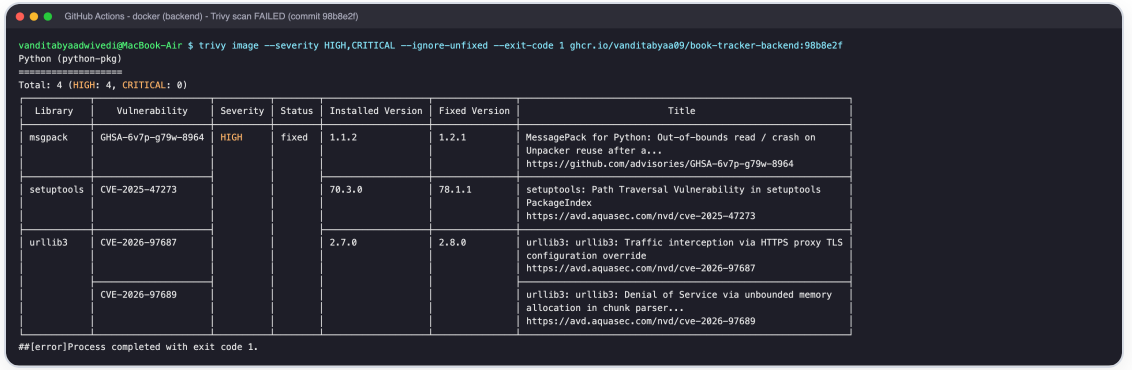
DevSecOps: the Trivy gate in action

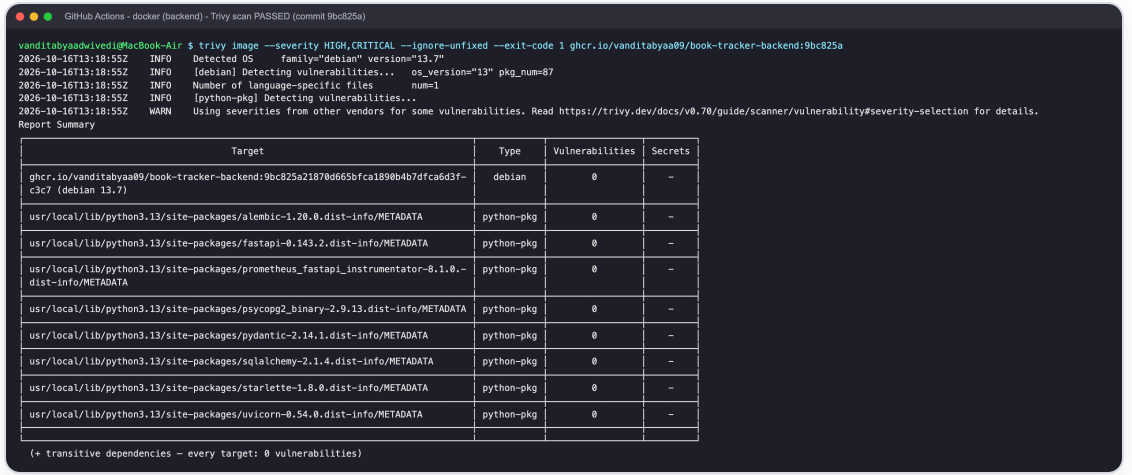
First scan: 4 HIGH CVEs in the backend image (setuptools, urllib3 ×2, msgpack).

Root cause: not our dependencies. They were copies *vendored inside pip* in the `python:3.13-slim` base image.

Fix: `pip uninstall -y pip` after installing requirements. There's no package manager at runtime, and the rescan is **0 vulnerabilities**.

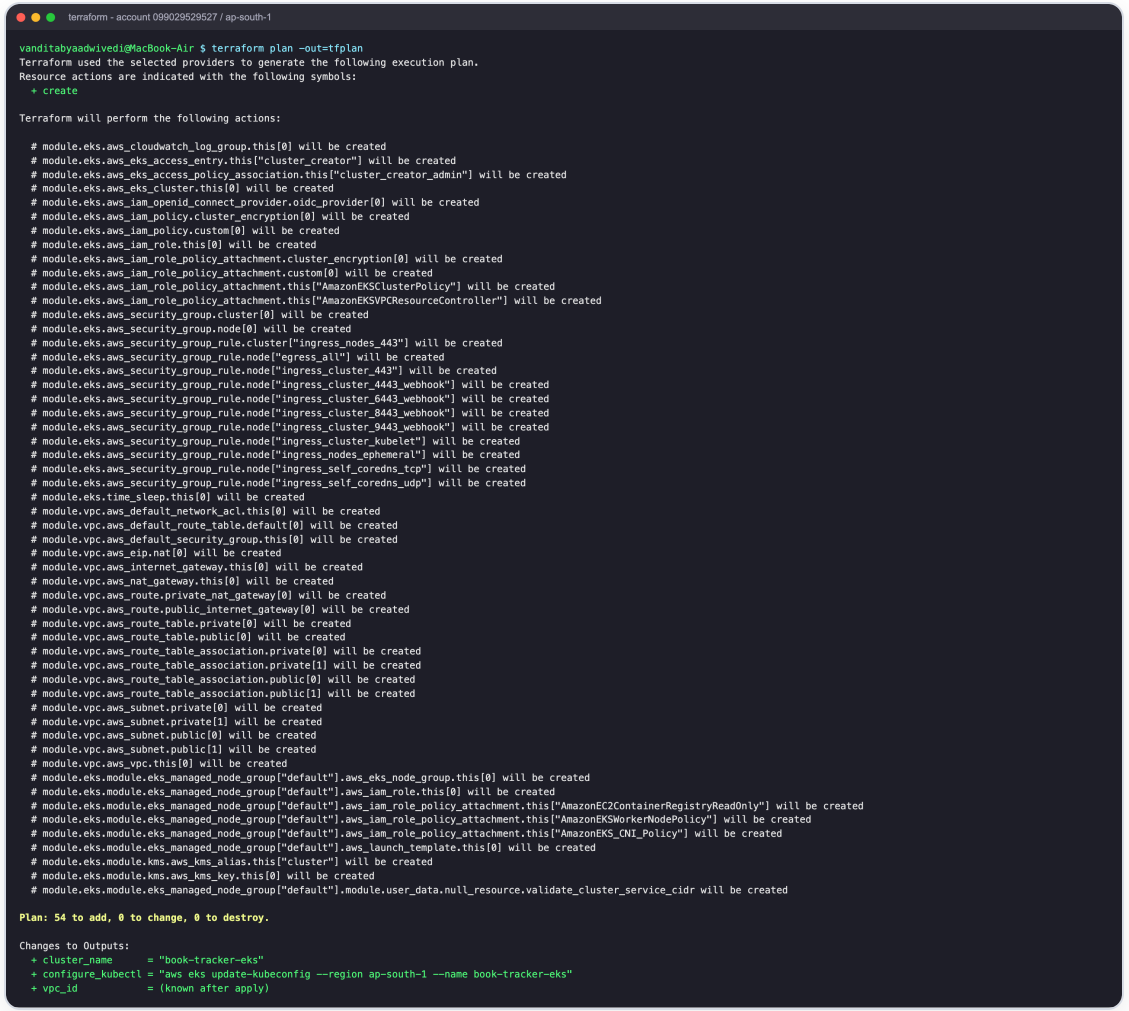
trivy-action pinned to a commit SHA, because mutable tags were hijacked in the March 2026 supply-chain attack.





Infrastructure as Code: Terraform → AWS

- **VPC** 10.0.0.0/16 across 2 AZs: **2 public** subnets (ELB) + **2 private** (nodes), IGW, NAT gateway
- **EKS 1.36** cluster, public API endpoint, creator granted admin via access entry
- **Managed node group:** 2 × m7i-flex.large (min 2 / max 3)
- `plan`: 54 resources · `apply` · `destroy` fully cleans up
- `terraform.tfvars.example` only; state and credentials are never committed

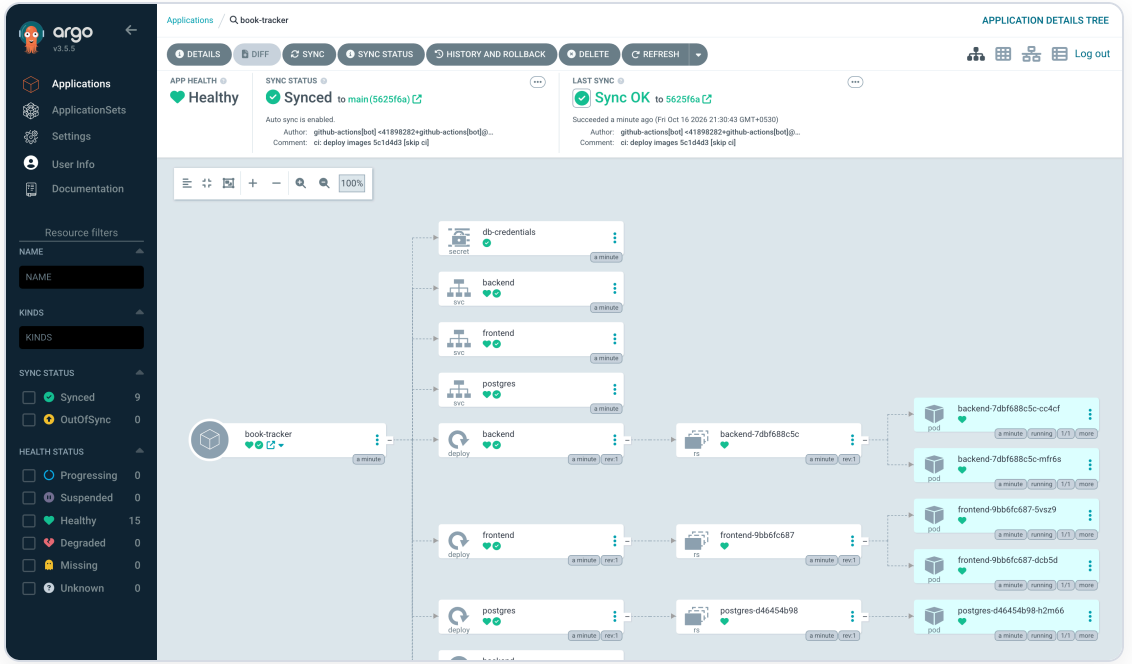


Kubernetes setup: Helm + ArgoCD

- Helm chart: Secret, Postgres, **backend ×2**, **frontend ×2** (runAsNonRoot, probes, resource limits)
- ClusterIP Services; **Ingress** routes `/api` → backend, `/` → frontend
- **ArgoCD** watches `helm/book-tracker` on `main`, with auto-sync, prune and self-heal
- GitOps: CI never touches the cluster; Git is the source of truth

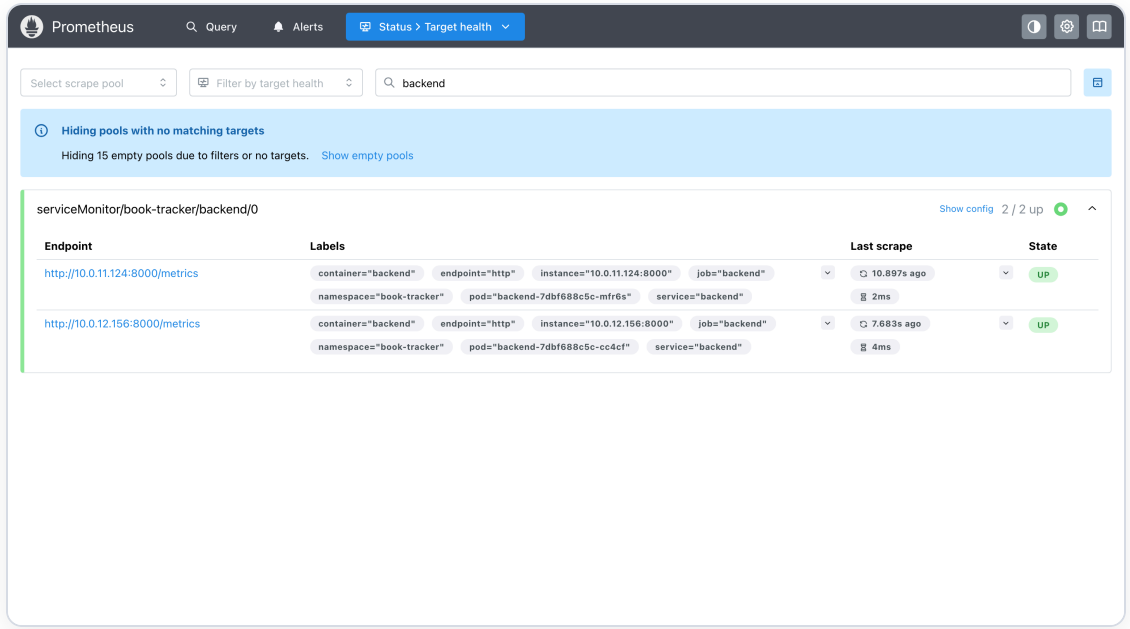
```
kubectl - EKS book-tracker-eks (account 099029529527)

vanditabyaadwivedi@MacBook-Air $ kubectl get pods -n book-tracker -o wide
NAME                        READY   STATUS    RESTARTS      AGE   IP            NODE                                          NOMINATED NODE   READINESS GATES
backend-7dbf688c5c-gnzzb    1/1     Running   1 (88s ago)   99s   10.0.11.228   ip-10-0-11-136.ap-south-1.compute.internal    <none>           <none>
backend-7dbf688c5c-qhb72    1/1     Running   1 (87s ago)   99s   10.0.12.204   ip-10-0-12-134.ap-south-1.compute.internal    <none>           <none>
frontend-9bb6fc687-g7fp2    1/1     Running   0             99s   10.0.11.196   ip-10-0-11-136.ap-south-1.compute.internal    <none>           <none>
frontend-9bb6fc687-q59x6    1/1     Running   0             99s   10.0.12.225   ip-10-0-12-134.ap-south-1.compute.internal    <none>           <none>
postgres-d46454b98-hnvf5    1/1     Running   0             99s   10.0.12.37    ip-10-0-12-134.ap-south-1.compute.internal    <none>           <none>
```



Observability: Prometheus + Grafana

- `/metrics` via prometheus-fastapi-instrumentator
- **ServiceMonitor** → Prometheus scrapes both backend replicas: **2/2 UP**
- Grafana dashboard (JSON in repo): **R**ate, **E**rrors, **D**uration, plus replicas UP
- Error panel deliberately fed with 404/422 test traffic





Key learnings

- **Security gates find real issues:** pip's vendored libraries carried HIGH CVEs we'd never have noticed
- **Pin by SHA, not tag:** supply-chain safety for third-party actions
- **Cloud accounts have hidden limits:** the Free plan silently rejected t3.large (found via CloudTrail)
- **Terraform is resumable:** interrupted apply/destroy runs were simply re-run against state
- **Debug the network too:** connection resets on ~1 MB CRDs → applied CRDs separately, `--skip-crds`
- **Kubernetes needs numeric UIDs** for `runAsNonRoot`
- **Clean teardown order** (ELB before VPC) avoids runaway bills
- **Next steps:** RDS, TLS via cert-manager, S3 remote state, multi-arch images, Gateway API